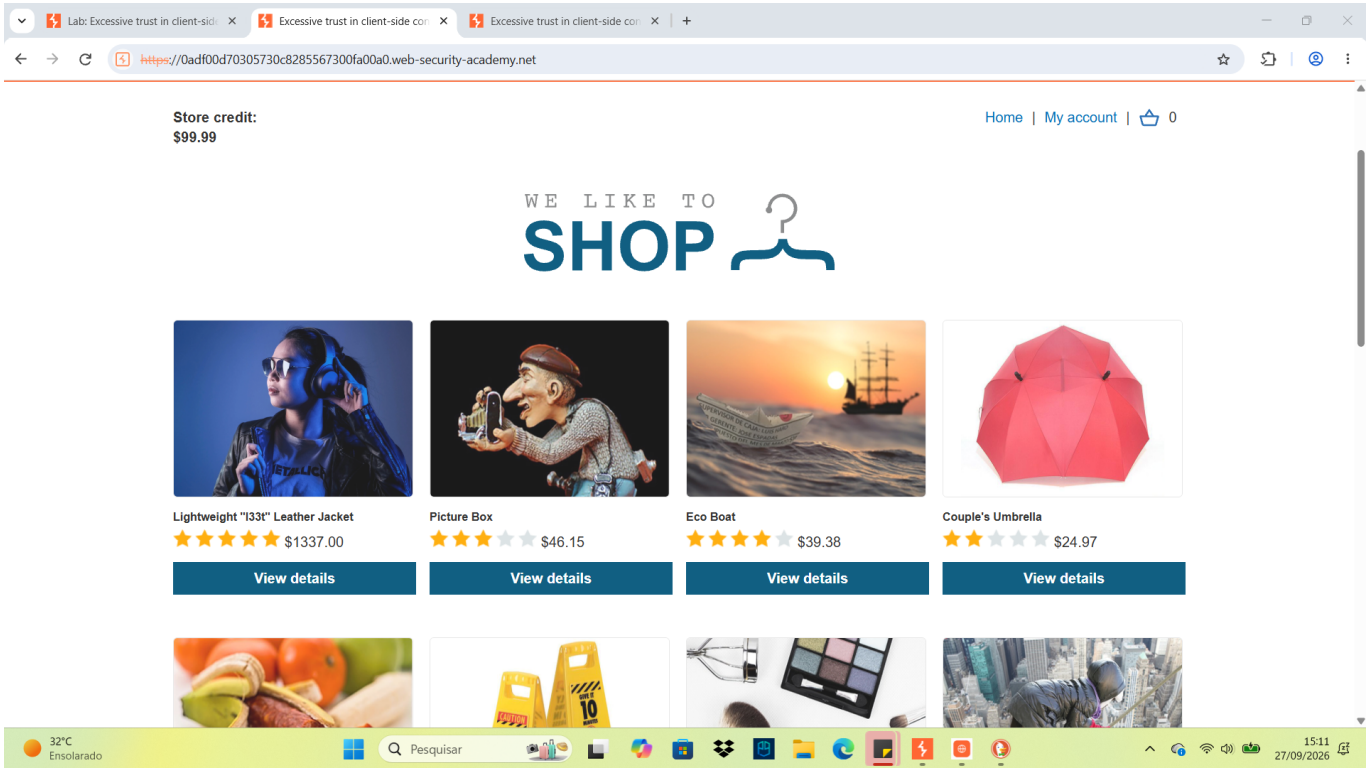
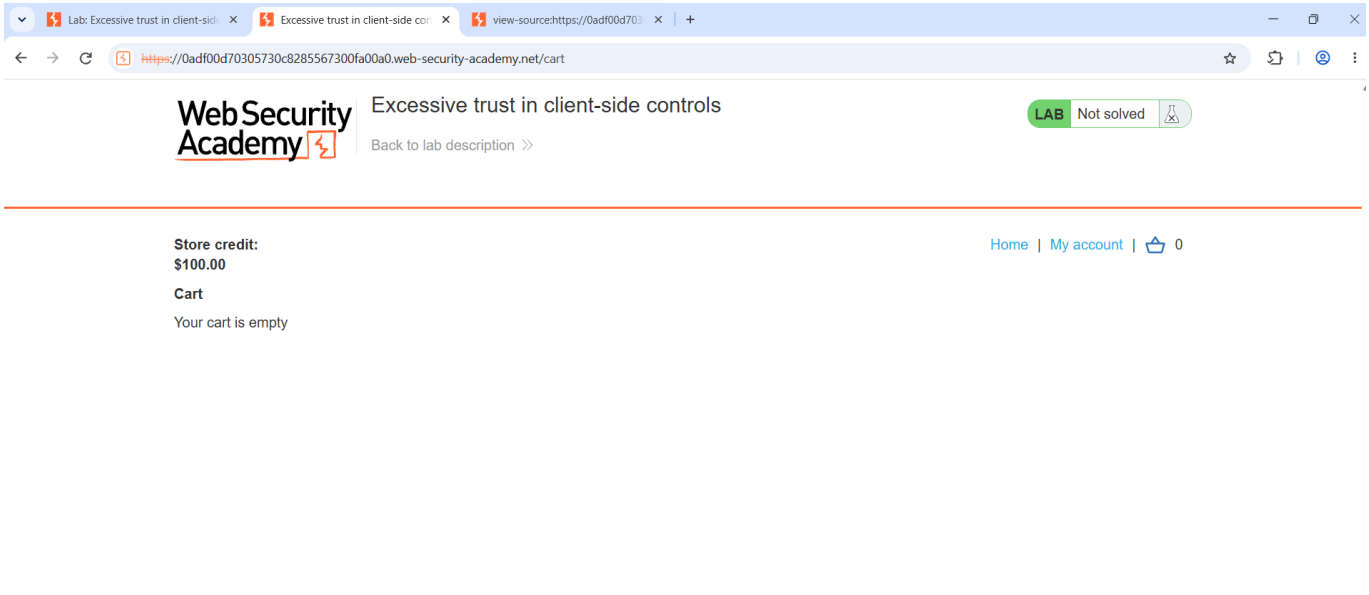
Lab: Excessive trust in client-side controls

PortSwigger Web Security Academy — Registro de resolução

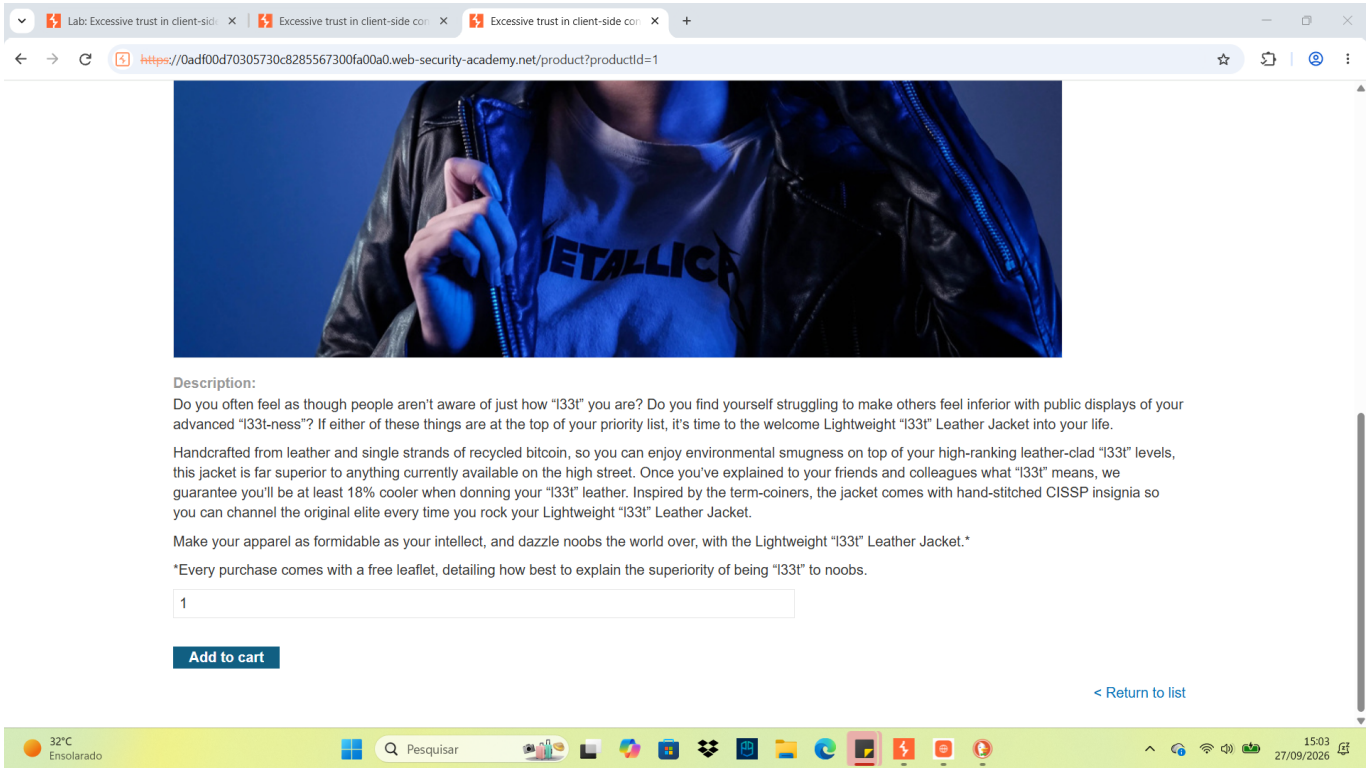
As imagens a seguir documentam, passo a passo, a exploração de uma falha de confiança excessiva em controles do lado do cliente. A aplicação é uma loja fictícia que envia o preço do produto (parâmetro *price*) junto com o restante do pedido, diretamente no corpo da requisição HTTP. Como o servidor confiava nesse valor em vez de recalculá-lo a partir do identificador do produto, foi possível interceptar a requisição no Burp Suite, alterar o preço manualmente e concluir a compra da jaqueta "Lightweight l33t Leather Jacket" — originalmente $1337,00 — por apenas $0,01.



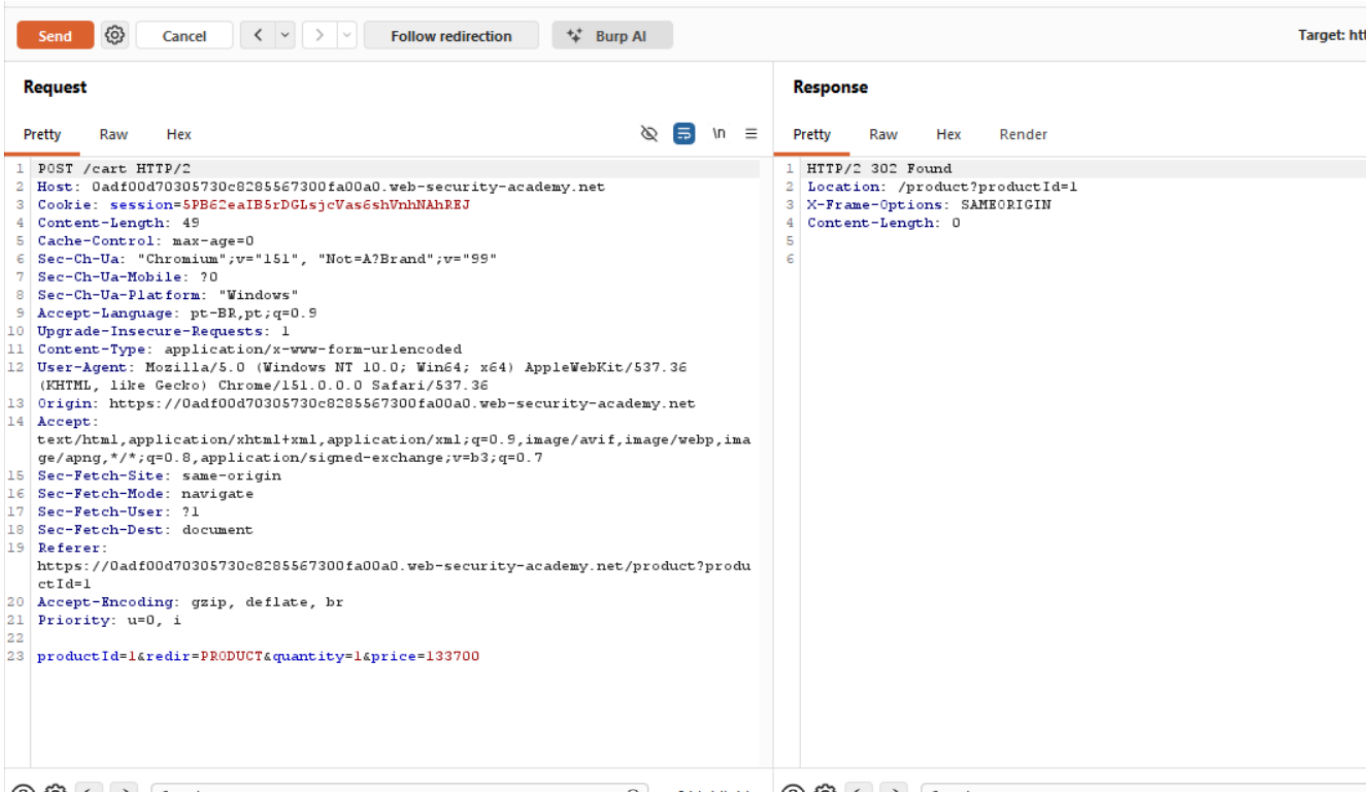
Página inicial da loja fictícia usada no laboratório, exibindo o crédito disponível na conta ($99,99) e os produtos à venda, entre eles a jaqueta-alvo.



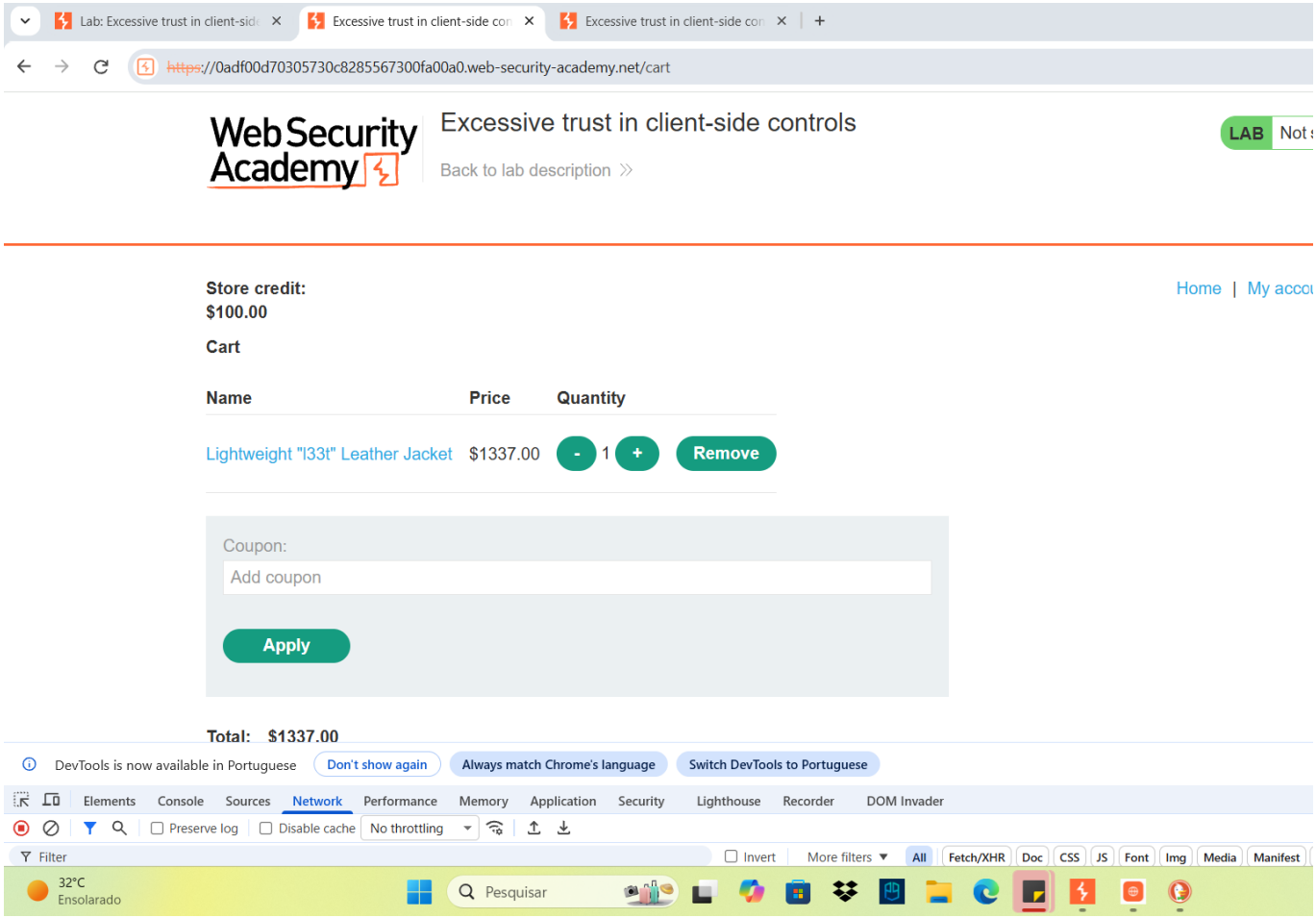
Carrinho de compras vazio, no início do teste, antes de qualquer item ser adicionado.



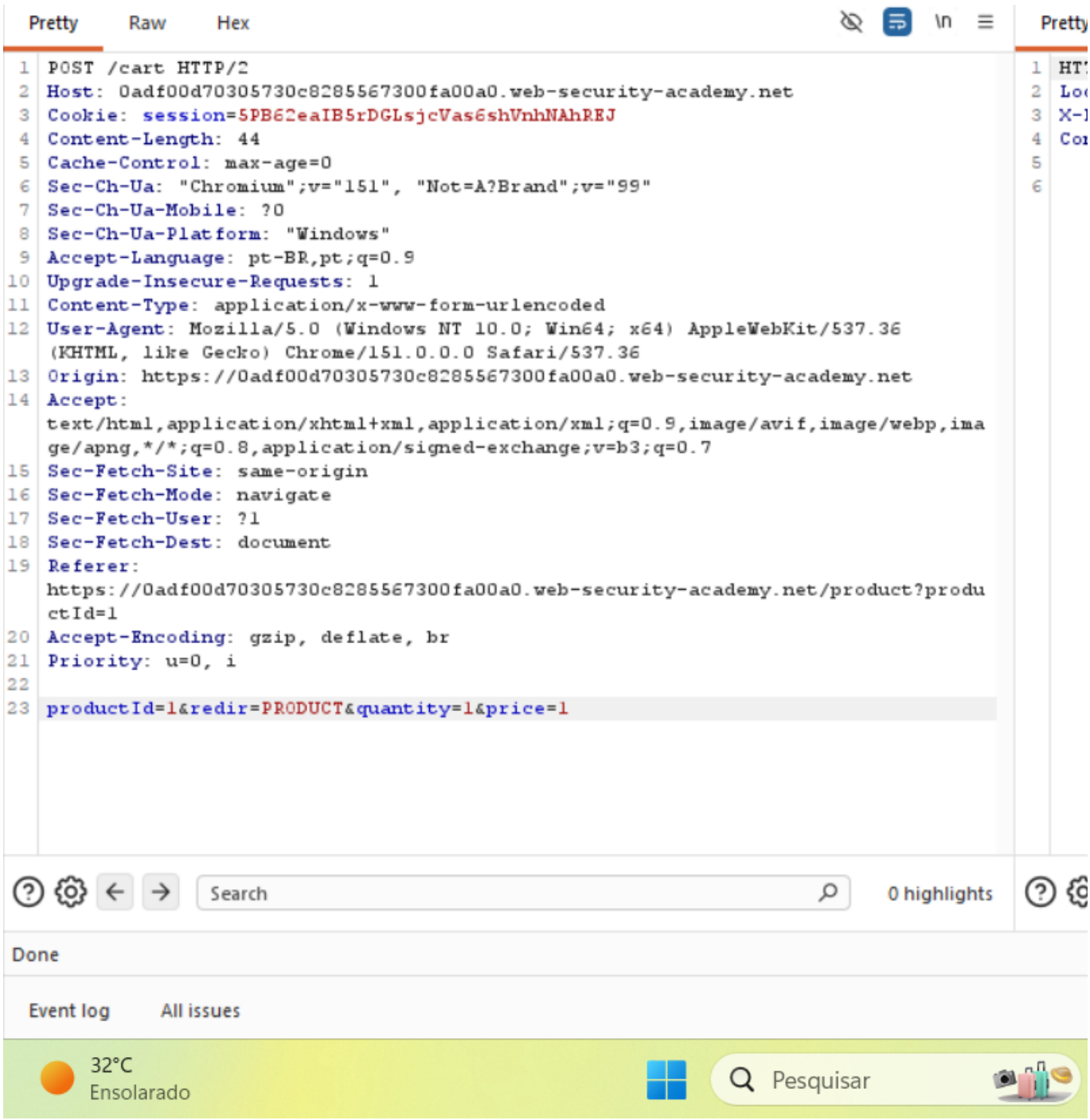
Página do produto "Lightweight l33t Leather Jacket", com preço original de $1337,00, prestes a ser adicionado ao carrinho.



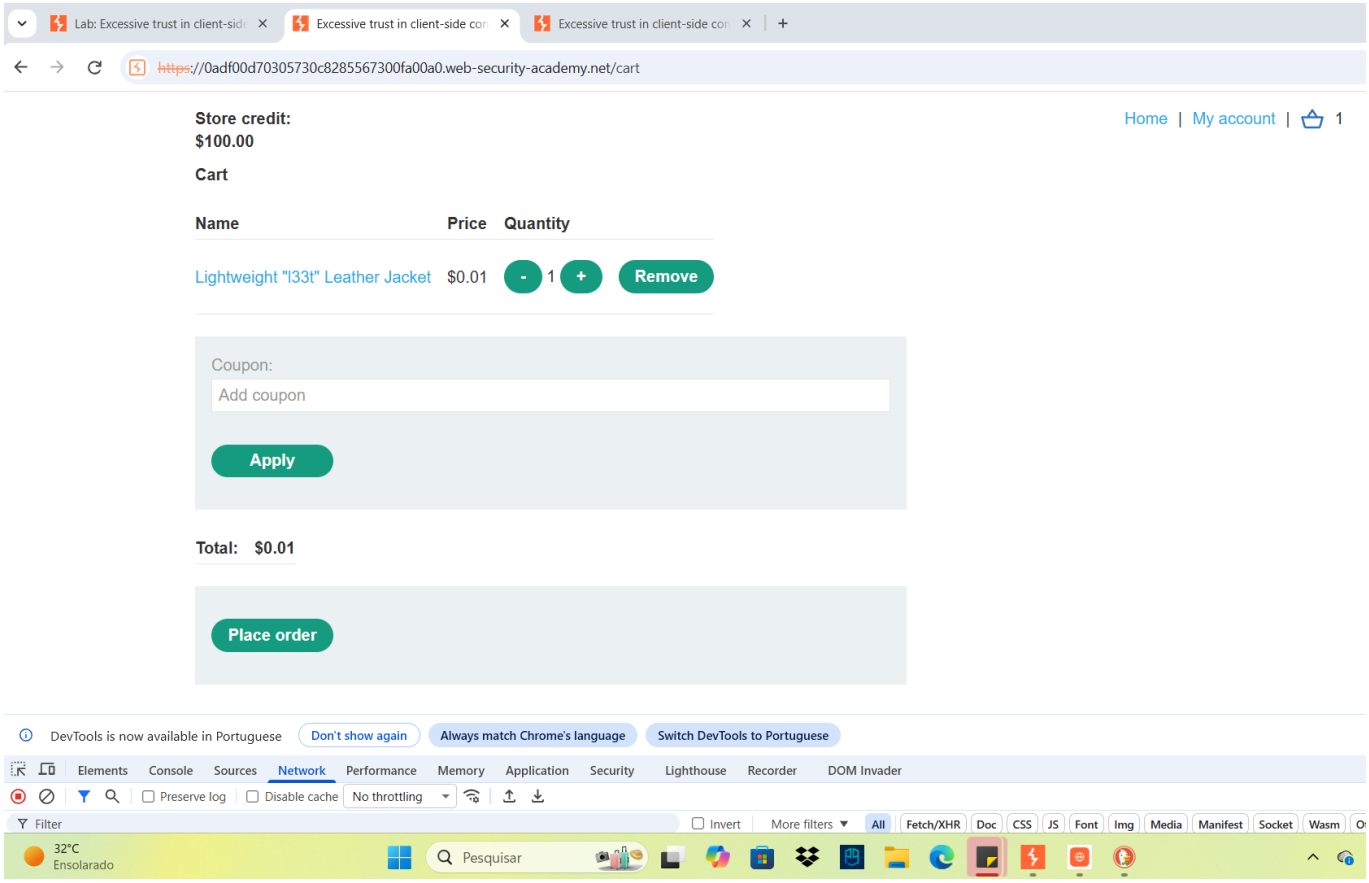
Requisição POST /cart interceptada no Burp Suite. O corpo da requisição expõe o parâmetro price (price=133700), enviado pelo próprio navegador — o indício da falha de confiança excessiva no cliente.



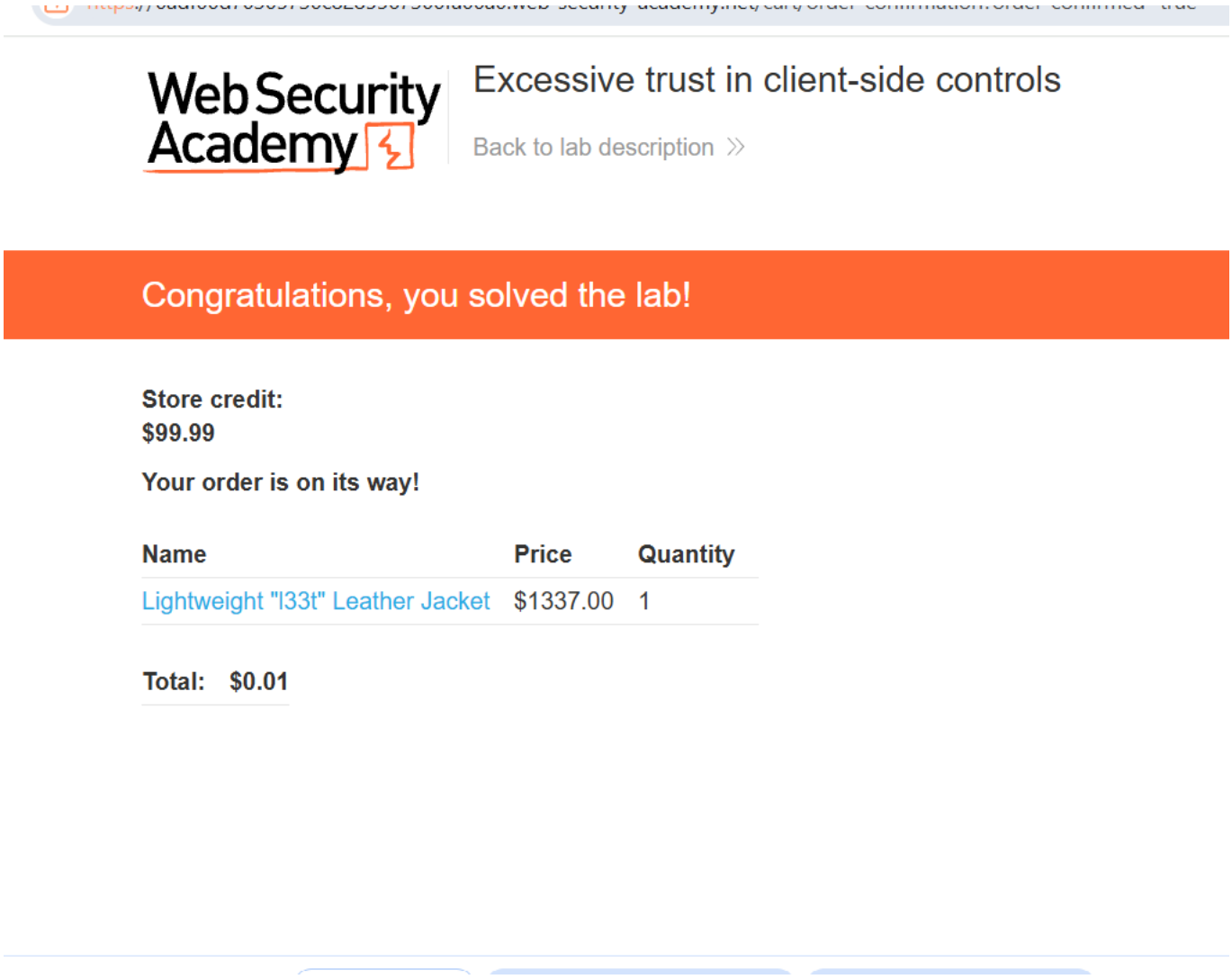
Carrinho já com o item adicionado, ainda pelo preço original ($1337,00), confirmando que a compra segue o fluxo normal até este ponto.



Requisição reenviada pelo Burp Repeater com o parâmetro alterado para price=1, manipulando o valor antes de o servidor processar o pedido.



Carrinho atualizado após o envio da requisição modificada: o total exibido caiu para $0,01, refletindo o valor manipulado.



Confirmação final do laboratório: pedido concluído com sucesso pelo valor alterado, validando a exploração da vulnerabilidade.